

Seguridad y Respaldo

1. Identificación de Datos Sensibles	2
2. Estrategia de Cifrado	2
2.1 Transparent Data Encryption (TDE)	2
2.2 Cifrado de columnas.....	2
2.3 Acceso a datos cifrados	2
3. Roles de Seguridad	3
3.1 Principios aplicados	3
4. Política de Respaldo (Backup)	3
4.1 Modelo de recuperación	3
4.2 Esquema de backups	4
4.3 Objetivos de recuperación	4
4.4 Almacenamiento y retención	4
4.5 Script de backup en T-SQL	4
4.6 Restauración.....	5
4.7 Monitoreo	5
5. Checklist de Verificación	5

1. Identificacion de Datos Sensibles

Se relevaron los datos del sistema y se identificaron las siguientes columnas como sensibles, de acuerdo con la normativa de proteccion de datos personales y buenas practicas de seguridad:

Tabla	Columna	Justificacion
Persona	DNI	Identificacion personal unica. Protegido por Ley 25.326 (PDPA Argentina).
Persona	Telefono	Dato de contacto personal. Sujeto a confidencialidad.
Guia	NumeroHabilitacion	Numero de registro profesional habilitante. Dato sensible laboral.
Historial	RazonEgreso	Informacion laboral de indole personal. Puede contener causas disciplinarias o medicas.

Columnas NO cifradas: NombrePersona, Apellido, Rol, Titulo del Guia, fechas de habilitacion, datos de parques, actividades, horarios.

2. Estrategia de Cifrado

2.1 Transparent Data Encryption (TDE)

Se evaluó originalmente la implementación de TDE para el cifrado de los archivos de datos (.mdf) y log (.ldf) en reposo. Sin embargo, debido a las limitaciones de la edición del motor utilizada (SQL Server Express Edition), la cual no soporta esta funcionalidad, se optó por descartar esta medida en favor de reforzar el cifrado a nivel de columna.

2.2 Cifrado de columnas

Las columnas identificadas como sensibles se cifran individualmente con clave simetrica AES-256. Esto garantiza que incluso un DBA con acceso al servidor no pueda leer esos datos sin la clave, y que en backups restaurados en otro servidor los datos permanezcan inaccesibles.

- Las columnas originales son eliminadas del esquema.
- Las columnas cifradas son de tipo VARBINARY.
- Se agrega una columna HashDNI (SHA-256) para detectar duplicados sin descifrar.

2.3 Acceso a datos cifrados

Los datos cifrados solo son accesibles a traves de SPs especificos que abren la clave simetrica, leen o escriben el dato, y cierran la clave. Ningun rol de aplicacion puede ejecutar OPEN SYMMETRIC KEY directamente, pn_admin y pn_auditoria si pueden.

- altaPersona: cifra DNI y Telefono al insertar.
- consultarPersona: descifra y retorna DNI y Telefono para roles autorizados.
- altaGuia: cifra NumeroHabilitacion al insertar.
- altaHistorial: cifra RazonEgreso al insertar.
- consultarHistorial: descifra RazonEgreso para auditoria.

3. Roles de Seguridad

Se implementa un esquema de minimo privilegio: ningun rol tiene acceso directo a las tablas del schema PnTablas salvo pn_admin y pn_auditoria. Toda operacion de datos pasa por SPs.

Rol	Descripcion	Schemas con EXECUTE	Acceso a Tablas	Cifrado	Backup
pn_admin	Administrador total del sistema	PnSPabm, PnSPtrans	PnTablas	Control total (clave y certificado)	BACKUP DATABASE / LOG
pn_operador	Operacion ABM	PnSPabm, PnSPtrans	Sin acceso directo	Sin acceso	Sin permiso
pn_importador	Importacion masiva de datos	PnSPtrans	Parque, Provincia, TipoParque, TipoActividad, Actividad (SELECT)	Sin acceso	Sin permiso
pn_consultas	Reportes y consultas de solo lectura	PnSPtrans	Tablas no sensibles (Parque, Actividad, Horarios, etc.)	Sin acceso	Sin permiso
pn_auditoria	Auditoria integral con datos descifrados	PnSPabm (consultarPersona, consultarHistorial)	SELECT en todo PnTablas	Control (clave y certificado) — solo lectura descifrada	Sin permiso

3.1 Principios aplicados

- **Minimo privilegio:** cada rol recibe unicamente los permisos indispensables para su funcion.
- **Separacion de responsabilidades:** quien importa datos no puede modificar configuracion; quien audita no puede modificar datos.
- **Sin acceso directo a tablas:** los roles operativos solo ejecutan SPs, nunca consultan ni modifican tablas directamente.
- **Denegacion en columnas cifradas:** pn_consultas tiene DENY sobre DNI_Cifrado y Telefono_Cifrado aunque tenga SELECT sobre la tabla Persona.

4. Politica de Respaldo (Backup)

4.1 Modelo de recuperacion

La base de datos se configura en modo de recuperacion FULL (FULL RECOVERY MODEL). Esto para realizar backups de log de transacciones, lo que minimiza la ventana de perdida de datos.

4.2 Esquema de backups

Tipo de Backup	Frecuencia	Retencion	Ventana de Ejecucion	Destino
Full	Semanal (Domingos)	4 semanas (4 copias)	-	Almacenamiento primario + offsite cifrado
Diferencial	Diario (Lun-Sab)	7 dias	-	Almacenamiento primario
Log (transaccional)	Cada 15 minutos	72 horas	Continuo	Almacenamiento primario + replicacion
Full (DR offsite)	Mensual (1er domingo)	12 meses	-	Almacenamiento offsite

(*) La hora de los backups full y diferencial conviene ejecutarlos durante el momento de menor actividad.

4.3 Objetivos de recuperacion

Objetivo	Valor	Fundamento
RPO (Recovery Point Objective)	15 min	Perdida maxima aceptable de 15 min de transacciones.
RTO (Recovery Time Objective)	2 hs	Tiempo maximo para restaurar el servicio en caso de falla critica.
MTTR (Mean Time To Repair)	< 1 hs	Objetivo de reparacion promedio para incidentes no criticos.

4.4 Almacenamiento y retencion

- **Destino primario:** ruta local en servidor de base de datos.
- **Destino secundario:** unidad de red o NAS en otro segmento de red, copiado automaticamente post-backup.
- **Destino offsite:** copia mensual en almacenamiento geograicamente separado.
- **Cifrado de backups:** todos los archivos de backup se cifran con el mismo certificado de TDE.
- **Verificacion:** RESTORE VERIFYONLY debe ejecutarse luego de cada backup full para confirmar integridad del archivo.

4.5 Script de backup en T-SQL

```
-- Backup FULL semanal
BACKUP DATABASE ParquesNacionales
TO DISK = N'D:\Backups\PN_Full_' + CONVERT(VARCHAR,GETDATE(),112) + '.bak'
WITH COMPRESSION, ENCRYPTION (ALGORITHM = AES_256,
    SERVER CERTIFICATE = CertTDE_ParquesNacionales), STATS = 10;

-- Backup LOG cada 15 minutos
BACKUP LOG ParquesNacionales TO DISK = N'D:\Backups\PN_Log_' +
CONVERT(VARCHAR,GETDATE(),112) + '_' + REPLACE(CONVERT(VARCHAR,GETDATE(),108),':','') +
'.bak' WITH COMPRESSION;
```

4.6 Restauracion

El proceso de restauracion ante desastres es el siguiente:

1. Restaurar el backup FULL mas reciente con NORECOVERY.
2. Aplicar el ultimo backup DIFERENCIAL disponible con NORECOVERY.
3. Aplicar todos los backups de LOG en orden cronologico hasta el ultimo disponible, el ultimo con RECOVERY.
4. Verificar integridad con DBCC CHECKDB.
5. Restaurar el certificado TDE desde el archivo de backup del certificado.

(*) El certificado TDE debe estar respaldado en una ubicacion segura y separada. Sin el certificado, los backups cifrados son irrecuperables.

4.7 Monitoreo

- Verificar en msdb.dbo.backupset que se ejecutaron correctamente todos los backups programados.
- Configurar alertas en SQL Server Agent para notificar fallos de backup via email (Database Mail).
- Revisar la tabla msdb.dbo.suspect_pages semanalmente para deteccion temprana de corrupcion.
- Ejecutar DBCC CHECKDB mensualmente en horario de baja actividad.

5. Checklist de Verificacion

Verificacion	Estado
TDE activado (sys.dm_database_encryption_keys)	IMPLEMENTADO
Columnas sensibles migradas a VARBINARY (cifradas)	IMPLEMENTADO
Columnas originales en texto claro eliminadas del esquema	IMPLEMENTADO
Clave simetrica protegida por certificado	IMPLEMENTADO
Roles creados con permisos minimos	IMPLEMENTADO
DENY explicito en columnas cifradas para rol consultas	IMPLEMENTADO
SPs de consulta descifran datos solo para roles autorizados	IMPLEMENTADO
Modelo de recuperacion configurado como FULL	PENDIENTE
Backup FULL semanal configurado en SQL Agent	PENDIENTE
Backup DIFERENCIAL diario configurado en SQL Agent	PENDIENTE
Backup LOG cada 15 min configurado en SQL Agent	PENDIENTE
Certificado TDE respaldado en ubicacion separada	PENDIENTE
Alertas de fallo de backup configuradas	PENDIENTE
Test de restauracion documentado	PENDIENTE